Attack Surface Analysis

This document presents the attack surface analysis for the mock email assistant application built with LangChain and a local LLM. The analysis maps every channel through which external data enters the system, evaluates whether the agent has direct visibility into that content, and outlines the prerequisites needed to inject adversarial instructions.

1. Page Text and Message Bodies

The primary entry channel consists of incoming email subject lines and body text parsed directly into the application prompt templates. The agent has direct, complete visibility into this content during execution. To introduce malicious instructions through this channel, an attacker only needs to send a standard email containing indirect prompt injection payloads. Because the assistant processes unsanitized email text directly within the LLM context window, no elevated privileges or authentication are required beyond sending a normal message.

2. Hidden Elements and Markup

HTML emails frequently contain non-visible elements, such as text inside `display:none` span tags, white on-white styled text, or zero pixel font containers. If the application's email parser converts HTML into plain text without stripping hidden DOM nodes, the agent sees this content clearly in its prompt. An attacker introduces instructions through this channel by embedding hidden payload markup inside an HTML email. The human recipient reading the rendered message sees a standard email, while the underlying LLM receives and executes the hidden instructions.

3. Images and Visual Content

Images enter the application via inline message graphics, file attachments, or remote image links. The agent only sees content from this channel if it utilizes a multimodal LLM or an automated optical character recognition (OCR) preprocessing pipeline. To execute an attack through this vector, an attacker must embed textual override commands directly into an image payload. If an OCR tool or multimodal parser transcribes the image text and passes it into the active context window, the model interprets the visual text as actionable instructions.

4. Document Metadata

Metadata channels include non body document properties attached to incoming files, such as PDF or Word document headers (Author, Title, Subject, and Comment fields). The agent sees this content conditionally when document loader tools are configured to extract metadata along with body text. An attacker introduces instructions by editing document properties prior to sending the attachment. When the assistant ingests the file and passes its metadata into the prompt context during summarization, the injected strings are processed by the LLM.

5. Tool Execution Results

Tool result channels carry external data returned to the agent when it invokes function calls, such as web searches, database queries, or external API integrations. The agent sees these tool outputs directly in subsequent reasoning turns. An attacker introduces instructions by poisoning the external data sources queried by the agent. When the assistant retrieves this external content during routine execution, the untrusted tool result enters the context as trusted instruction data.